si4care — Rencana Migrasi Backend

Dari prototipe frontend-only → MariaDB 10.4 + Drizzle ORM + Better Auth

Disusun 17 Juni 2026 · Diperbarui **22 Juni 2026** · Status: ✓ Fase 0–3 + Hardening selesai · Tim: 2 orang

> **Cara pakai dokumen ini:** Fase mengikuti penomoran Fase 1/2/3 yang sudah ada di `prd.md` §1 — bukan urutan baru. Tiap langkah mencantumkan file prototipe yang akan diganti, supaya jelas titik mulainya. Centang tiap kotak saat selesai, lalu ringkas progres ke `checklist.md` di akhir sesi kerja.

Ringkasan Progres — 22 Juni 2026

✓ Fase 0 Setup	✓ Fase 1 MVP	✓ Fase 2 Domain Lanjutan	✓ Fase 3 Stock/Blog/Backup	✓ Hardening Paralel

⏳ Deploy & Production

0. Keputusan Stack (ringkasan ADR-0001)

Lapisan	Pilihan	Status
Framework	Next.js 16 App Router — Server Actions + Route Handlers	✓ Aktif
Database	**MariaDB 10.4** via XAMPP (dev lokal); MySQL 8 untuk staging/prod	✓ Aktif
ORM	**Drizzle ORM** + drizzle-kit (schema push)	✓ Aktif
Auth	Better Auth — email/password + Google OAuth, session di DB	✓ Aktif
Cache / Queue	Upstash Redis (cache ongkir 24 jam, antrean webhook/email)	⏳ Terpasang, belum live
Pembayaran	Midtrans (Snap + Core + webhook)	⏳ Snap terpasang; webhook signature belum live
Ongkir	RajaOngkir/Komerce + fallback tabel ongkir cadangan	⏳ Fallback aktif; API live belum dikonfigurasi
Deployment	Vercel atau VPS (Docker + PM2) + SSL	⏳ Belum deploy produksi

Alasan: tim kecil (2 orang) sudah familiar MySQL/SQL, satu stack menghindari overhead cross-stack, dan ini konsisten dengan `prd.md` §5–§6 yang sudah menetapkan arsitektur ini sejak awal proyek — bukan keputusan baru, hanya dikonfirmasi ulang supaya tidak dipertanyakan lagi di sesi berikutnya.

PERSIAPAN — SEBELUM FASE 1 MVP

Fase 0 — Setup Project

Semua item selesai ✓

- [x] Install dependensi: `drizzle-orm` `mysql2` `drizzle-kit` `better-auth` `@upstash/redis` `zod` (sesuai `prd.md` §10) — Selesai
- [x] Setup MariaDB 10.4 via XAMPP (dev lokal) — *catatan: diputuskan pakai XAMPP/MariaDB bukan Docker MySQL 8 karena lebih ringan untuk dev lokal 2 orang; schema kompatibel dengan MySQL 8* — Selesai
- [x] Isi `.env.local`: `DATABASE_URL`, `REDIS_URL`, `MIDTRANS_*`, `RAJAONGKIR_*`, `BETTER_AUTH_SECRET`, `GOOGLE_CLIENT_ID/SECRET` — Selesai
- [x] Buat struktur folder `src/lib/db`, `src/lib/auth`, `src/lib/services`, `src/lib/validations`, `src/actions` — sesuai `prd.md` §5.2 — Selesai
- [x] Catat ADR-0001 final di `docs/adr/0001-backend-stack.md` — Selesai

PRD.MD FASE 1

Fase 1 — MVP

Katalog/varian/batch · Online shop + checkout Midtrans · Ketahanan ongkir · POS dasar · PPN · Laporan & ledger

1.1 Schema dasar & Auth

- [x] Tabel `users` + sesi/akun (Better Auth generate) — form di `login/page.tsx` & `register/page.tsx` sudah terhubung; data hardcode "Budi Santoso" diganti — Selesai
- [x] Konfigurasi Better Auth (email/password + Google OAuth) + middleware role (`super_admin` / `admin` / `customer`) — sidebar admin & account sudah terhubung sesi nyata — Selesai
- [x] Tabel `addresses` + server actions CRUD (`createAddress`, `updateAddress`, `deleteAddress`, `setPrimaryAddress`) — Zod + anti-IDOR sudah terpasang — Selesai

1.2 Katalog: kategori → produk → varian → batch

- [x] Tabel `categories` — server actions CRUD terpasang; foto masih data-URL (object storage direncanakan saat deploy produksi) — Selesai
- [x] Tabel `products`, `variants` (kolom `attributes` JSON, `activePrice`, `minStock`, `stockMode`, `barcode`) — dua model produk disatukan; `mock-data.ts` dipindah ke `src/lib/mock-data.ts` — Selesai
- [x] Tabel `batches` (HPP per batch, tanggal ED, tanggal terima, remaining) — menggantikan `INBOUND_RECENT_BATCHES` dan `POS_CATALOG.hpp` di mock-data — Selesai
- [x] FIFO/FEFO engine (`lib/utils/stockAllocation.ts`) sesuai algoritma di `prd.md` §8.2 — fungsi murni, dipakai bersama oleh checkout web, POS, dan stock opname — Selesai

1.3 Online shop: keranjang → checkout → Midtrans

- [x] Tabel `cart_items` + server actions add/remove/update cart — menggantikan `CartContext.tsx` React state murni — Selesai
- [x] Checkout: alamat tersimpan + ongkir (fallback tabel; RajaOngkir API belum live) + voucher + PPN 12% — menggantikan `shippingCost = 25000` hardcode di `checkout/page.tsx` — Selesai
- [x] Tabel `outbound_transactions`, `outbound_items`, `batch_allocations`, `ledger_entries` — skema lengkap sesuai `prd.md` §6 — Selesai
- [x] Integrasi Midtrans Snap — Snap token dibuat di server (`src/lib/midtrans.ts`); Dialog checkout sudah pakai token nyata — Selesai
- [ ] Webhook `/api/webhooks/midtrans` — verifikasi signature SHA-512 + status `paid` → `allocateStockAndLedger` sesuai alur di `prd.md` §8.1 ⚠ *Belum live — signature verification perlu API key produksi*

1.4 POS dasar

- [x] Sambungkan KasirTab ke katalog & stok asli via `getPosProducts()` — menggantikan `POS_CATALOG` mock; scan barcode mode terpasang — Selesai
- [x] Kalkulasi diskon/PPN/MDR diekstrak ke `src/lib/pos-calc.ts` — murni, reusable, dipakai POS + marketplace settlement — Selesai
- [x] Transaksi POS menulis ke `outbound_transactions` (`channel='pos'`) + `ledger_entries` + alokasi batch FIFO/FEFO — sama seperti checkout web — Selesai

1.5 Laporan & ledger dasar

- [x] Semua angka hardcode di `admin/reports/page.tsx` diganti jadi query agregat dari `ledger_entries` / `outbound_transactions` — filter periode, channel, KPI cards, chart, top produk — Selesai

PRD.MD FASE 2

Fase 2

Barcode/scan · Subsidi ongkir · Diskon/voucher · Marketplace + settlement · FEFO + alarm ED · Retur

- [x] Barcode 1D/QR — `barcode.tsx` terhubung ke kolom `variants.barcode`; mode scan POS via Enter pada input autoFocus — Selesai
- [x] Subsidi ongkir engine — disimpan ke `app_settings` (bukan `useState` lokal); server action `getShippingSubsidy` / `saveShippingSubsidy` — Selesai
- [x] Voucher & diskon berjenjang — tabel `vouchers` + CRUD penuh; `incrementVoucherUsage` atomic SQL increment untuk cegah race condition; diskon berjenjang ke `app_settings` — Selesai
- [x] Marketplace + settlement — tabel `outbound_transactions` (`channel='marketplace'`); `validateSettlement` server action; `marketplaceFees` JSON menyimpan komisi/MDR/biaya layanan kustom per platform — Selesai
- [x] FEFO untuk item ber-ED — engine FIFO/FEFO di Fase 1.2 sudah mendukung; set `stockMode='fefo'` per varian di halaman admin produk — Selesai
- [x] Alarm on-the-fly — `src/actions/alarms.ts` query langsung dari DB: stok < minimum (via HAVING), batch mendekati ED ≤30 hari, batch kadaluarsa, margin tipis/negatif; dismiss ephemeral di client — Selesai
- [x] Retur — tabel `returns` + alur karantina (pending → inspeksi → layak_jual / write_off / ditolak); halaman customer + admin; `src/actions/returns.ts` dengan Zod + anti-IDOR — Selesai

PRD.MD FASE 3

Fase 3

Stock opname · Backup terjadwal · Blog SEO · Multi-cabang

- [x] Stock opname — tabel `stock_opname_sessions` + `stock_opname_items`; `startSoSession()` snapshot semua varian aktif; `closeSession()` terapkan delta ke `batches.remaining` via FIFO; riwayat sesi 20 terakhir — Selesai
- [x] Backup database terjadwal — `.github/workflows/db-backup.yml`: cron 02:00 WIB (`0 19 * * *` UTC) + `workflow_dispatch`; `mysqldump --single-transaction | gzip`; artifact 30 hari; slot B2/S3 siap uncomment. Script lokal: `npm run db:backup` — Selesai
- [x] Blog SEO — tabel `articles`; `src/actions/articles.ts` (CRUD, auto-slugify, Zod); `blog/page.tsx` server component dari DB; `blog/[slug]/page.tsx`: `generateMetadata()` (title, description, openGraph, Twitter card, canonical) + JSON-LD schema.org `Article` — Selesai
- [x] Multi-cabang MVP — tabel `branches` + default row `('main', 'Toko Utama')`; kolom `branch_id VARCHAR(36) DEFAULT 'main'` di `outbound_transactions`, `orders`, `ledger_entries`, `stock_opname_sessions` — Selesai

Di luar scope prd.md — perlu keputusan owner: fitur chat (`account/chat/page.tsx`, `admin/messages/page.tsx`) tidak disebut di `prd.md` sama sekali. Opsional & prioritas rendah — kalau dilanjutkan, implementasi paling sederhana: polling tabel `chat_threads` / `chat_messages`, websocket belakangan.

PARALEL — DITERAPKAN DI SETIAP SLICE

Hardening

Validasi · AuthZ · Audit log · Anti-rugi · Kepatuhan QRIS

- [x] **Validasi Zod + authZ per resource (anti-IDOR)** — `src/lib/server-auth.ts`: helper `requireAdmin()` + `requireSession()` shared. Dipasang di: `marketplace-settlement.ts` (sebelumnya 0 auth), `vouchers.ts` (semua admin mutations), `returns.ts` (admin role check), `articles.ts` (admin role check). Validasi Zod: `submitReturn`, `upsertArticle`, `validateSettlement`. Pelanggan hanya bisa akses order/alamat/retur miliknya sendiri (IDOR guard via `AND userId = session.userId`). — Selesai
- [x] **Audit log untuk aksi sensitif** — tabel `audit_logs` (`userId`, `action`, `entityType`, `entityId`, `detail` JSON, `createdAt`). Helper `src/lib/audit.ts` — never throws (audit failure tidak boleh block transaksi). Log dipasang di: ubah status pesanan admin (`ORDER_STATUS_CHANGED`), validasi settlement marketplace (`SETTLEMENT_VALIDATED`), tutup sesi stock opname (`STOCK_OPNAME_CLOSED`), harga jual di bawah HPP (`PRICE_BELOW_HPP`). — Selesai
- [x] **Anti-rugi: tolak bila `activePrice < hpp` batch yang dikonsumsi** — terpasang di `savePosTransaction` (POS) dan `createOrder` (online). Setelah alokasi batch FIFO/FEFO, cek `unitPrice < avgHpp`; tolak dengan error deskriptif + log `PRICE_BELOW_HPP` di audit log. — Selesai
- [x] **Kepatuhan QRIS: tidak ada surcharge ke pelanggan** — dropdown POS tidak lagi menampilkan "0.7% MDR" di nama metode pembayaran. MDR row di ringkasan berubah jadi "MDR X% *(ditanggung toko)*". QR dialog: "Pelanggan bayar {total} · MDR 0.7% ditanggung toko". `SERVICE_FEE` di `orders.ts` tetap flat Rp 4.500 untuk semua metode tanpa surcharge per-metode. — Selesai

Sisa Pekerjaan (belum dikerjakan)

⏳ Item yang masih perlu diselesaikan sebelum produksi

- [ ] **Webhook Midtrans** — verifikasi signature SHA-512 di `/api/webhooks/midtrans`; trigger `allocateStockAndLedger` saat status `settlement`/`capture`. Butuh API key produksi Midtrans.
- [ ] **Ongkir live RajaOngkir/Komerce** — saat ini masih fallback tabel ongkir cadangan; perlu konfigurasi API key + cache Redis 24 jam + uji cakupan wilayah
- [ ] **Security lanjutan** — output escaping XSS di body artikel, CSRF token di form non-Server-Action, security headers (CSP/HSTS/X-Frame-Options) via `next.config`, akun DB non-root least-privilege untuk koneksi ORM
- [ ] **Tests** — unit test untuk `stockAllocation.ts`, `pos-calc.ts`, logika diskon; e2e Playwright untuk alur checkout + POS + retur
- [ ] **Admin orders page** — saat ini masih menggunakan `initialOrders` mock; perlu server component yang load dari tabel `orders` DB dengan filter/search asli. Status pesanan menggunakan enum DB (`pending_payment`, `processing`, `shipped`, `delivered`, `cancelled`)
- [ ] **Foto produk** — ganti ilustrasi SVG placeholder → `next/image` + object storage (Cloudflare R2 / S3-compatible); upload dari admin dashboard
- [ ] **Deploy produksi** — Vercel atau VPS (`output: "standalone"` di `next.config`); SSL; konfigurasi MySQL 8 managed atau self-host; cetak struk thermal ESC/POS + label barcode 33×15mm; uji restore backup berkala
- [ ] **Chat pelanggan ↔ admin** (opsional, di luar scope prd.md) — polling sederhana tabel `chat_threads` / `chat_messages`; websocket belakangan jika ada kebutuhan

Catatan Hosting MySQL (tim 2 orang, tanpa DBA dedicated)

Opsi	Kapan dipilih
Managed (Aiven, PlanetScale, DigitalOcean Managed DB)	Kalau tidak mau pusing soal backup/restore — sedikit lebih mahal, tapi failover & backup otomatis sudah ditangani
Self-host di VPS yang sama dengan Next.js	Lebih murah, sejalan dengan rencana awal "VPS ≥1GB + swap" di `checklist.md` — backup (`mysqldump` + cron via GitHub Actions) jadi tanggung jawab sendiri
MariaDB 10.4 via XAMPP + Adminer	Dev lokal aktif saat ini — schema kompatibel dengan MySQL 8; mudah lihat tabel via Adminer tanpa command line; migrasi ke MySQL 8 di prod transparan